

Technical Security Assessment Report Phishing Simulation & Awareness Portal

This technical security assessment evaluates the security posture of the Phishing Simulation & Awareness Portal, a web-based application designed to educate staff or students about phishing attacks through controlled simulation and awareness training. The assessment focuses on identifying vulnerabilities within the application's authentication mechanisms, tracking infrastructure, access control, and data handling processes.

The scope of this assessment includes the frontend React application, backend Node.js (Express) API, authentication and authorisation mechanisms, phishing campaign tracking endpoints, and the underlying MySQL database accessed via phpMyAdmin. Testing was conducted in a local development environment to simulate realistic attack scenarios while avoiding harm to real users or data.

The assessment identified three primary security findings: the absence of rate limiting on authentication endpoints, the potential abuse of publicly accessible tracking endpoints, and design considerations around CSRF protection when using token-based authentication. While none of these vulnerabilities represent critical system compromise, they pose moderate risks related to account security and data integrity if left unmitigated.

Overall, the system demonstrates a strong baseline security design, including role-based access control, input sanitisation, audit logging, and secure password storage. The identified issues can be mitigated through relatively straightforward enhancements such as rate limiting, anomaly detection, and clearer security documentation. With these improvements, the platform would be well-positioned for safe educational deployment.

Methodology

Tools Used

The following tools were used during the assessment:

- **Web Browser Developer Tools** (Chrome/Edge)
Used to inspect HTTP requests, responses, headers, and client-side behaviour.
- **Postman / curl**
Used to manually test backend API endpoints and simulate malicious requests.
- **phpMyAdmin**
Used to inspect database tables, stored records, and audit logs.

- **Visual Studio Code**
Used for static code analysis of backend controllers, middleware, and routes.
- **Node.js Console Logs**
Used to observe runtime behaviour and authentication events.

Testing Approach

A hybrid testing approach was adopted:

- **Black-box testing:**
The application was tested from a user's perspective through the frontend UI, without assuming knowledge of internal logic.
- **Grey-box testing:**
Partial knowledge of the backend API and database schema was used to explore edge cases and abuse scenarios.
- **Static analysis:**
Backend source code was reviewed to identify insecure patterns, missing controls, and defensive mechanisms.

Testing focused on authentication, authorisation, event tracking, and data integrity rather than infrastructure-level attacks, as the system is intended for controlled educational use.

Assessment Framework

The assessment aligns with the **OWASP Top 10** web application security risks and incorporates principles from the **STRIDE** threat modelling methodology, particularly:

- Spoofing (authentication abuse)
- Tampering (tracking data manipulation)
- Repudiation (audit logging)
- Information disclosure (token misuse)

Security Findings

Finding 1: Lack of Rate Limiting on Login Endpoint

Description

The authentication endpoint (`/api/auth/login`) allows unlimited login attempts. During testing, repeated incorrect login attempts were accepted without delay or restriction.

Exploit Scenario

An attacker could automate repeated login attempts using a dictionary or brute-force attack, attempting to guess user passwords. While bcrypt hashing protects stored passwords, repeated attempts still increase the likelihood of account compromise.

Impact

- Increased risk of account takeover
- Potential unauthorised access to campaign data and analytics
- Increased load on authentication services

Likelihood

Moderate — brute-force tools are widely available and easy to use.

Business Context Impact

If an administrator account were compromised, an attacker could manipulate campaigns, falsify training metrics, or misuse the platform to distribute real phishing emails.

Finding 2: Public Accessibility of Tracking Endpoints

Description

Tracking endpoints (/track/:token, /click/:token, /report/:token) are intentionally public to allow email recipients to interact without authentication. However, these endpoints can be accessed repeatedly using the same token.

Exploit Scenario

An attacker could repeatedly request a tracking URL to artificially inflate open or click rates, compromising the integrity of campaign metrics.

Impact

- Loss of trust in reported training metrics
- Incorrect assessment of staff security awareness
- Reduced effectiveness of awareness programmes

Likelihood

Low to Moderate — requires knowledge of a valid tracking token.

Business Context Impact

Inaccurate metrics may lead to poor security decisions, misallocation of training resources, or false confidence in organisational readiness.

Finding 3: CSRF Design Considerations with Token-Based Authentication

Description

The application uses JWT-based authentication stored on the client side. While CSRF protection middleware is implemented, its necessity and coverage depend on how tokens are stored and transmitted.

Exploit Scenario

If authentication tokens were stored in cookies without strict CSRF enforcement, an attacker could attempt cross-site request forgery attacks. In the current design, tokens are sent via headers, reducing CSRF risk.

Impact

- Limited in current design
- Risk increases if authentication storage method changes

Likelihood

Low — current implementation mitigates most CSRF attack vectors.

Business Context Impact

Primarily a design and documentation risk rather than an immediate exploit.

4. Evidence

7. Conclusion

The Phishing Simulation & Awareness Portal demonstrates a solid security foundation suitable for an educational environment. Core security principles such as RBAC, audit logging, input validation, and secure password handling are correctly implemented. The identified vulnerabilities are moderate and manageable, with clear remediation paths.

Addressing these findings would further strengthen the platform's resilience, data integrity, and trustworthiness. With recommended improvements applied, the system would meet both functional and security expectations for a controlled phishing awareness training environment.

Use variables: {{link}}, {{recipient_email}}, {{report_link}}

Email Body (HTML)

```
<p>Hello,</p>
<p>We detect</p>
<p>Please ve</p>
<p>{{link}}>Ve</p>
<p>If this wasn't you, report this email here: <a href="{{report_link}}">Report</a></p>
<p>Regards,<br/>IT Security Team</p>

```

localhost:3000 says

Campaign created successfully!

OK

Available variables: {{link}}, {{recipient_email}}, {{report_link}}

Recipients (one email per line) *

```
test1@example.com
test2@example.com
test3@example.com
test4@example.com
test5@example.com
```

Maximum 1000 recipients. Line count: 5

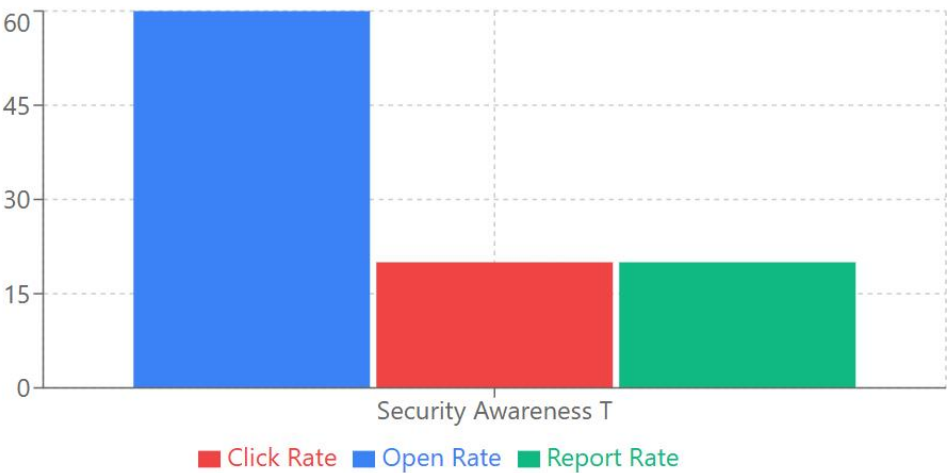
⚠ Ethical Use Warning

This tool is for educational purposes only. All recipients should be informed this is a training exercise. Never use this to harm, deceive, or collect real sensitive information.

Creating...

Cancel

Campaign Performance



Campaigns

NAME	STATUS	RECIPIENTS	OPEN RATE	CLICK RATE	REPORT RATE	ACTIONS
Security Awareness Training – Week 2 07/01/2026	active	5	60.0%	20.0%	20.0%	View Delete



Total Campaigns

1

Total Recipients

5

Avg Click Rate

20.0%

Avg Report Rate

20.0%

Campaign Performance





Phishing Portal

Security Awareness Training Platform

Login failed

admin@phishing-portal.local

.....

Sign in

Default credentials:

Email: admin@phishing-portal.local

Password: admin123



You've Been Phished!

Don't worry - this was a training exercise.

You clicked on a simulated phishing link. In a real attack, your information could have been compromised.

What is Phishing?

Phishing is a cyber attack where criminals use fraudulent emails to trick you into revealing sensitive information like passwords or credit card numbers. These attacks often appear to come from trusted sources.

Why This Training Matters

Over 90% of successful cyber attacks start with phishing. By recognizing these attacks, you become your organization's first line of defense.

Red Flags to Watch For



Suspicious Sender

Email from unknown or misspelled domain



Urgent Language

Creates false sense of urgency or threat



Suspicious Links

Hover to reveal actual destination URL



Requests Info

Asks for passwords or sensitive data



Poor Grammar

Spelling errors and awkward phrasing



Generic Greeting

'Dear Customer' instead of your name



Unexpected Attachments

Suspicious files or executables



Too Good to Be True

Unrealistic prizes or offers

What Should You Do?

- 1 Think Before You Click**
Always verify sender and hover over links
- 2 Report Suspicious Emails**
Forward to IT security team immediately
- 3 Verify Through Other Channels**
Call sender using known phone number
- 4 Keep Software Updated**
Update OS, browser, and antivirus regularly

Remember

This was a training exercise. No real harm was done, and no data was collected.

[Return to Dashboard](#)

Server: 127.0.0.1 > Database: phishing_portal > Table: audit_logs

BrowseStructureSQLSearchInsertExportImportPrivilegesOperationsTrackingTriggers

Showing rows 0 - 12 (13 total, Query took 0.0021 seconds.)

SELECT * FROM `audit\_logs`

Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

☐ Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Extra options

	id	user_id	action	resource_type	resource_id	details	ip_address	timestamp
☐ Edit Copy Delete	0b9f40e9-ec5f-11f0-8114-bc0358a591d1	d60eb86a-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60eb86a-ec5b-11f0-8114-bc0358a591d1	{ "email": "sumaya@portal.local", "role": "admin" }	::1	2026-01-08 06:55:40
☐ Edit Copy Delete	51c7fbbe-ec60-11f0-8114-bc0358a591d1	d60eb86a-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60eb86a-ec5b-11f0-8114-bc0358a591d1	{ "email": "sumaya@portal.local", "role": "admin" }	::1	2026-01-08 07:04:50
☐ Edit Copy Delete	52420a5a-ec8f-11f0-8114-bc0358a591d1	d60eb86a-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60eb86a-ec5b-11f0-8114-bc0358a591d1	{ "email": "sumaya@portal.local", "role": "admin" }	::1	2026-01-08 12:41:17
☐ Edit Copy Delete	5e5942d0-ec60-11f0-8114-bc0358a591d1	d60ed704-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60ed704-ec5b-11f0-8114-bc0358a591d1	{ "email": "alex@portal.local", "role": "instructor" }	::1	2026-01-08 07:05:11
☐ Edit Copy Delete	6e4eb54b-ec5f-11f0-8114-bc0358a591d1	d60ed7c9-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60ed7c9-ec5b-11f0-8114-bc0358a591d1	{ "email": "joan@portal.local", "role": "viewer" }	::1	2026-01-08 06:58:23
☐ Edit Copy Delete	7bd908b9-ecfc-11f0-8114-bc0358a591d1	NULL	LOGIN	user	NULL	{ "email": "admin@phishing-portal.local" }	NULL	2026-01-07 22:59:12
☐ Edit Copy Delete	7bddc92f-ec1c-11f0-8114-bc0358a591d1	NULL	CREATE_CAMPAIGN	campaign	NULL	{ "name": "Security Awareness Training - Week 2" }	NULL	2026-01-07 22:59:12
☐ Edit Copy Delete	7bdd904f-ec1c-11f0-8114-bc0358a591d1	NULL	LAUNCH_CAMPAIGN	campaign	NULL	{ "recipients": 5 }	NULL	2026-01-07 22:59:12
☐ Edit Copy Delete	8ceda621-ec5e-11f0-8114-bc0358a591d1	d60eb86a-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60eb86a-ec5b-11f0-8114-bc0358a591d1	{ "email": "sumaya@portal.local", "role": "admin" }	::1	2026-01-08 06:52:08
☐ Edit Copy Delete	9e65712-ec59-11f0-8114-bc0358a591d1	NULL	LAUNCH_CAMPAIGN	campaign	bee21737-ec58-11f0-8114-bc0358a591d1	{ "recipientCount": 5 }	::1	2026-01-08 06:16:47
☐ Edit Copy Delete	9cf9d507-ec5e-11f0-8114-bc0358a591d1	d60ed7c9-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60ed7c9-ec5b-11f0-8114-bc0358a591d1	{ "email": "joan@portal.local", "role": "viewer" }	::1	2026-01-08 06:52:35
☐ Edit Copy Delete	ae5be7a3-ec5e-11f0-8114-bc0358a591d1	d60ed704-ec5b-11f0-8114-bc0358a591d1	LOGIN	user	d60ed704-ec5b-11f0-8114-bc0358a591d1	{ "email": "alex@portal.local", "role": "instructor" }	::1	2026-01-08 06:53:04
☐ Edit Copy Delete	beebe457-ec58-11f0-8114-bc0358a591d1	NULL	CREATE_CAMPAIGN	campaign	bee21737-ec58-11f0-8114-bc0358a591d1	{ "name": "Security training", "recipientCount": 5 }	::1	2026-01-08 06:10:35

Console

☐ Check all | With selected: Edit Copy Delete Export

☐ Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Query results operations

Print Copy to clipboard Export Display chart Create view

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

Server: 127.0.0.1 > Database: phishing_portal > Table: campaigns

Browse Structure SQL Search Insert Export Import Privileges Operations Tracking Triggers

Showing rows 0 - 1 (2 total, Query took 0.0014 seconds.)

SELECT * FROM `campaigns`

Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

Show all Number of rows: 25 Filter rows: Search this table Sort by key: None

Extra options

	id	name	template_subject	template_body	created_by	scheduled_at	status	created_at
☐	7bb083f4-ec1c-11f0-8114-bc0358a591d1	Security Awareness Training – Week 2	Action Required: Verify Your University Account	Dear user, We detected unusual sign-in ...	NULL	NULL	active	2026-01-07 22:59:12
☐	bee21737-ec58-11f0-8114-bc0358a591d1	Security training	Urgent: Action Required – Verify Your Account	<p>Hello,</p><p>We detected unusual activity on y...	NULL	NULL	active	2026-01-08 06:10:35

Check all With selected: Edit Copy Delete Export

Show all Number of rows: 25 Filter rows: Search this table Sort by key: None

Query results operations

Print Copy to clipboard Export Display chart Create view

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

Console

Server: 127.0.0.1 > Database: phishing_portal > Table: events

Browse Structure SQL Search Insert Export Import Privileges Operations Tracking Triggers

Showing rows 0 - 14 (15 total, Query took 0.0065 seconds.)

SELECT * FROM `events`

Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

Show all Number of rows: 25 Filter rows: Search this table Sort by key: None

Extra options

	id	recipient_id	event_type	ip_address	user_agent	timestamp
☐	13b043d3-ec61-11f0-8114-bc0358a591d1	7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	clicked	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	2026-01-08 07:10:15
☐	1852a095-ec59-11f0-8114-bc0358a591d1	bee7887b-ec58-11f0-8114-bc0358a591d1	clicked	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	2026-01-08 06:13:05
☐	5392789c-ec59-11f0-8114-bc0358a591d1	bee7887b-ec58-11f0-8114-bc0358a591d1	opened	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	2026-01-08 06:14:44
☐	7bcf1e25-ec1c-11f0-8114-bc0358a591d1	7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	sent	NULL	NULL	2026-01-07 22:59:12
☐	7bcf7fd0-ec1c-11f0-8114-bc0358a591d1	7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	opened	NULL	NULL	2026-01-07 22:59:12
☐	7bcf8b1a-ec1c-11f0-8114-bc0358a591d1	7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	clicked	NULL	NULL	2026-01-07 22:59:12
☐	7bcf8e9d-ec1c-11f0-8114-bc0358a591d1	7bc030f6-ec1c-11f0-8114-bc0358a591d1	sent	NULL	NULL	2026-01-07 22:59:12
☐	7bcf930f-ec1c-11f0-8114-bc0358a591d1	7bc030f6-ec1c-11f0-8114-bc0358a591d1	opened	NULL	NULL	2026-01-07 22:59:12
☐	7bcf973b-ec1c-11f0-8114-bc0358a591d1	7bc03de7-ec1c-11f0-8114-bc0358a591d1	sent	NULL	NULL	2026-01-07 22:59:12
☐	7bcf9baa-ec1c-11f0-8114-bc0358a591d1	7bc04275-ec1c-11f0-8114-bc0358a591d1	sent	NULL	NULL	2026-01-07 22:59:12
☐	7bcfa2fb-ec1c-11f0-8114-bc0358a591d1	7bc04275-ec1c-11f0-8114-bc0358a591d1	opened	NULL	NULL	2026-01-07 22:59:12
☐	7bcfa764-ec1c-11f0-8114-bc0358a591d1	7bc04275-ec1c-11f0-8114-bc0358a591d1	reported	NULL	NULL	2026-01-07 22:59:12
☐	7bcfab75-ec1c-11f0-8114-bc0358a591d1	7bc04623-ec1c-11f0-8114-bc0358a591d1	sent	NULL	NULL	2026-01-07 22:59:12
☐	b1b4eac2-ec95-11f0-8114-bc0358a591d1	7bc03de7-ec1c-11f0-8114-bc0358a591d1	opened	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	2026-01-08 13:26:54
☐	ee388374-ec60-11f0-8114-bc0358a591d1	7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	clicked	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36	2026-01-08 07:09:13

Check all With selected: Edit Copy Delete Export

Show all Number of rows: 25 Filter rows: Search this table Sort by key: None

Query results operations

Print Copy to clipboard Export Display chart Create view

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

Console

Server: 127.0.0.1 > Database: phishing_portal > Table: recipients

Browse Structure SQL Search Insert Export Import Privileges Operations Tracking Triggers

Showing rows 0 - 6 (7 total, Query took 0.0023 seconds.)

SELECT * FROM `recipients`

Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Extra options

	id	campaign_id	email	tracking_token	created_at			
☐				7bbf9fd5-ec1c-11f0-8114-bc0358a591d1	7bb083f4-ec1c-11f0-8114-bc0358a591d1	student1@example.com	1111-aaaa-2222-bbbb	2026-01-07 22:59:12
☐				7bc030f6-ec1c-11f0-8114-bc0358a591d1	7bb083f4-ec1c-11f0-8114-bc0358a591d1	student2@example.com	3333-cccc-4444-dddd	2026-01-07 22:59:12
☐				7bc03de7-ec1c-11f0-8114-bc0358a591d1	7bb083f4-ec1c-11f0-8114-bc0358a591d1	student3@example.com	5555-eeee-6666-ffff	2026-01-07 22:59:12
☐				7bc04275-ec1c-11f0-8114-bc0358a591d1	7bb083f4-ec1c-11f0-8114-bc0358a591d1	staff1@example.com	7777-gggg-8888-hhhh	2026-01-07 22:59:12
☐				7bc04623-ec1c-11f0-8114-bc0358a591d1	7bb083f4-ec1c-11f0-8114-bc0358a591d1	staff2@example.com	9999-iii-0000-jjjj	2026-01-07 22:59:12
☐				bee7887b-ec58-11f0-8114-bc0358a591d1	bee21737-ec58-11f0-8114-bc0358a591d1	test1@example.com	c10c8fbd-f220-4603-8ad3-1bf1f2c0927	2026-01-08 06:10:35
☐				bee7f89e-ec58-11f0-8114-bc0358a591d1	bee21737-ec58-11f0-8114-bc0358a591d1	test2@example.com	d97c2863-7ee8-4688-bad3-eebb85736cc7	2026-01-08 06:10:35

Check all | With selected:

Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Query results operations

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

Console

phpMyAdmin

Recent Favourites

- New
- coursework
- information_schema
- mysql
- performance_schema
- phishing_portal
 - New
 - audit_logs
 - campaigns
 - events
 - recipients
 - users
- phpmyadmin
- test

Server: 127.0.0.1 > Database: phishing_portal > Table: users

Browse Structure SQL Search Insert Export Import Privileges Operations Tracking Triggers

Showing rows 0 - 2 (3 total, Query took 0.0015 seconds.)

SELECT * FROM `users`

Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Extra options

	id	email	password_hash	role	created_at			
☐				d60eb86a-ec5b-11f0-8114-bc0358a591d1	sumaya@portal.local	\$2b\$10\$1hnNL1MGjsx3dNZXq73ZOmYLea2Xr9TGBrasBQ.uz...	admin	2026-01-08 06:32:42
☐				d60ed704-ec5b-11f0-8114-bc0358a591d1	alex@portal.local	\$2b\$10\$SpSDdp4pCVGP50AnzrSVHupEWwzc0GxVWTNXvcSINL...	instructor	2026-01-08 06:32:42
☐				d60ed7c9-ec5b-11f0-8114-bc0358a591d1	joan@portal.local	\$2b\$10\$YEKe4jcnDbx90pSWZqAeeXxeWqDT12iwVicAUgqj...	viewer	2026-01-08 06:32:42

Check all | With selected:

Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Query results operations

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

Console